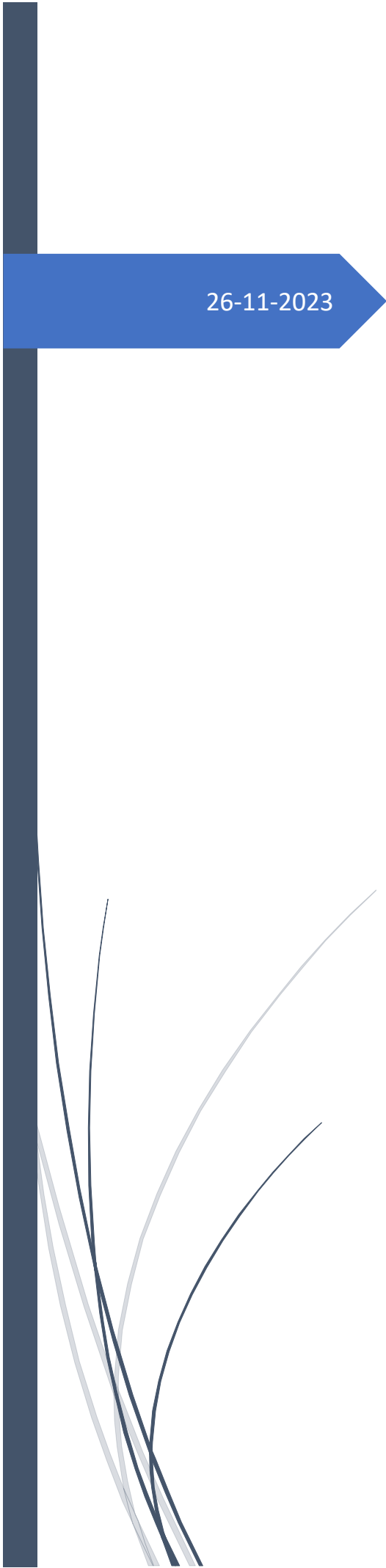


A thick dark blue vertical bar runs down the left side of the page. A blue arrow-shaped banner points to the right from this bar, containing the date. Below the banner, several thin, curved lines in dark blue and light grey sweep upwards from the bottom left corner.

26-11-2023

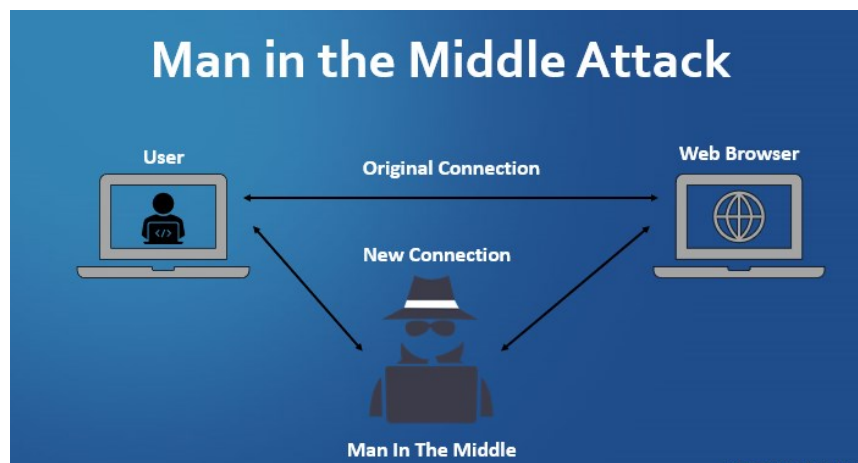
AMENAZAS AVANZADAS

NATALIA GÁMEZ BAREA
SERGI ROMAGUERA BORRÁS

ÍNDICE

Man-in-the-middle	3
Botnet	7
Ransomware	12
Bombas Lógicas	14

Man-in-the-middle



El ataque de Man-in-the-Middle es una técnica utilizada por un atacante para interceptar la comunicación entre dos partes, actuando como un intermediario invisible. Este ataque permite alterar la información que se intercambia entre ellos.

Entonces compromete la privacidad e integridad de la comunicación entre dos partes y también tiene la capacidad de leer, modificar o modificar datos en esa comunicación sin que ninguna de las partes sea consciente de su presencia.

Sus tipos de ataques principales son:

ARP Spoofing (Envenenamiento de ARP):

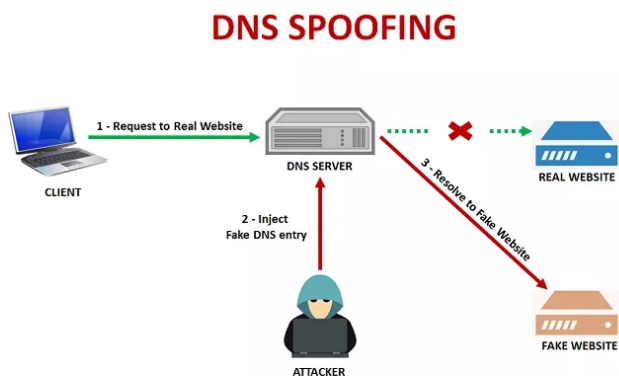


El atacante emplea un método conocido como envenenamiento de ARP para manipular las tablas de direcciones MAC a IP en una red local. Esto se logra emitiendo tramas ARP falsificadas que

asocian direcciones MAC incorrectas con direcciones IP legítimas.

Esta táctica le permite interceptar y potencialmente modificar o monitorear la comunicación que originalmente debería haberse dirigido al destino apropiado.

DNS Spoofing (Envenenamiento de DNS)



Manipula las respuestas del Sistema de Nombres de Dominio (DNS), asociando direcciones IP falsas con nombres de dominio

legítimos.

Esto redirige a los usuarios a sitios web falsificados o maliciosos cuando intentan acceder a los sitios reales.

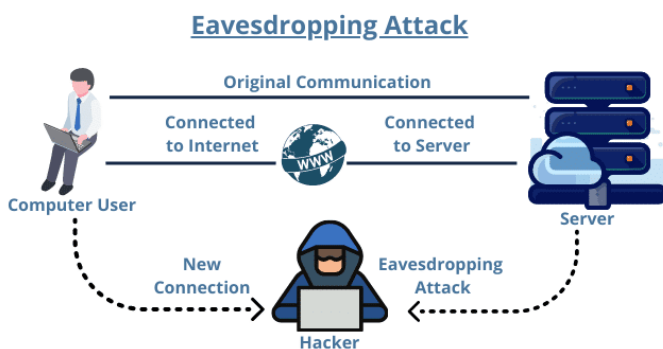
SSL Stripping



El atacante intercepta las conexiones HTTPS y las convierte a HTTP, eliminando la capa de seguridad SSL/TLS.

Esto permite al atacante leer y modificar los datos transmitidos entre el usuario y el servidor, ya que la información se envía de forma no cifrada.

Wi-Fi Eavesdropping (Escucha en Redes Wi-Fi)



En entornos con redes Wi-Fi inseguras, el atacante puede interceptar y espiar las comunicaciones entre dispositivos y puntos de

acceso Wi-Fi.

Lo que le permite capturar información sensible transmitida por el aire (contraseñas , fotografías , documentos confidenciales, etc.

Session Hijacking (Secuestro de Sesión)



El atacante toma el control de una sesión válida entre dos partes y puede acceder a información confidencial o realizar acciones en nombre

del usuario legítimo al hacerse pasar por él.

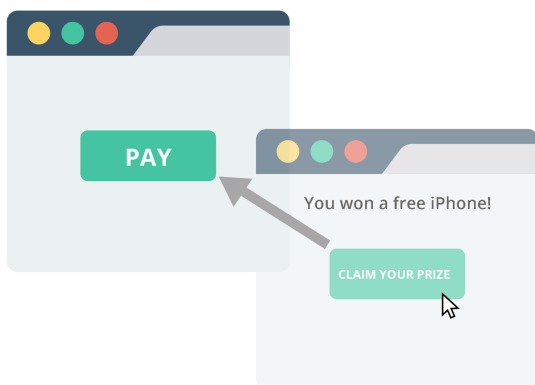
Email Hijacking (Secuestro de Correo Electrónico)



Se interceptan los correos electrónicos entre dos partes, permitiendo al atacante leer, modificar o incluso enviar mensajes

en nombre de los usuarios legítimos.

Clickjacking

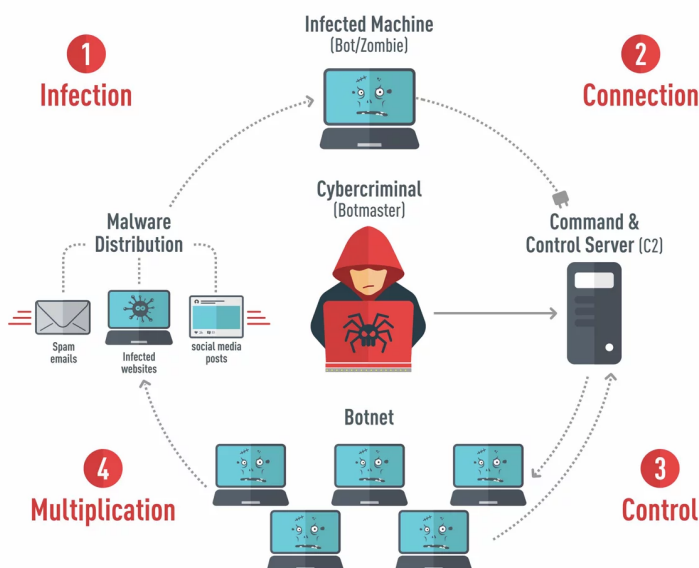


Las aplicaciones bancarias móviles, aunque consideradas seguras, pueden ser vulnerables al proporcionar a los cibercriminales datos valiosos, como credenciales de inicio de sesión y detalles de contacto.

El clickjacking muestra la efectividad y frecuencia de este tipo de delitos al permitir a los hackers ocultar una interfaz de usuario entre el usuario y la pantalla, posibilitando el robo de información confidencial.

Este método engañoso hace que al introducir tus datos de acceso, parezca que estás interactuando con la pantalla genuina de la aplicación bancaria, cuando en realidad puede ser una pantalla falsa superpuesta sobre la auténtica. Los bancos no verifican la información introducida, lo que facilita que los cibercriminales obtengan datos de cuentas bancarias al dirigir esta información a sus servidores para su robo.

Botnet



Una botnet es una red de dispositivos informáticos comprometidos, controlados de manera remota por un atacante o grupo de atacantes conocidos como "botmasters".

Los dispositivos pueden ser ordenadores, celulares inteligentes, servidores e incluso otros dispositivos conectados a internet que son infectados por malware especializado, lo que les permite ser controlados.

El propósito de una botnet es realizar acciones maliciosas sin el conocimiento de los propietarios legítimos de los dispositivos.

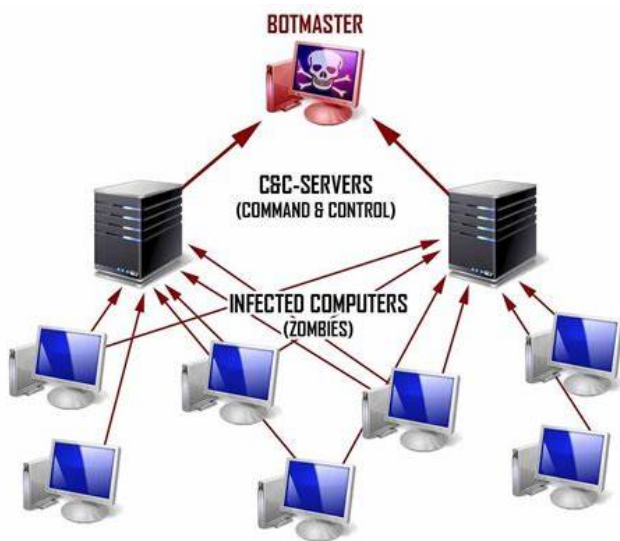
Una vez que un dispositivo se ve comprometido y se incorpora a una botnet, puede recibir órdenes de los "botmasters" para llevar a cabo una serie de actividades ilícitas.

Puede utilizarse para :

- **Ataques DDoS:** Sobrecargar servidores o redes con tráfico coordinado, volviéndolos inaccesibles.
- **Envío de Spam:** Enviar grandes volúmenes de correos no deseados o mensajes maliciosos.
- **Robo de Datos y Contraseñas:** Para obtener información confidencial como datos personales o credenciales.
- **Cryptojacking:** Usar recursos de los dispositivos para minar criptomonedas sin permiso.
- **Ataques de Fuerza Bruta:** Intentos masivos de acceder a sistemas adivinando contraseñas.

Los tipos de Botnet principales son:

Según Protocolos de Comunicación



Estas Botnets se diferencian por cómo los dispositivos infectados se comunican con el servidor central (C&C).

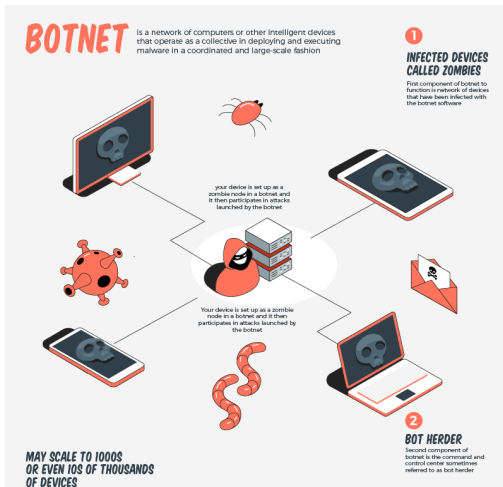
Algunas utilizan protocolos estándar de comunicación (como HTTP o IRC) para operar, mientras que otras pueden emplear métodos más sofisticados y

menos convencionales para evitar detección.

Según Estructura

Las Botnets varían en su arquitectura y organización.

Pueden ser centralizadas, donde un nodo principal controla todos los dispositivos infectados, descentralizadas, con múltiples nodos de control distribuidos o incluso sin estructura definida (P2P), donde los dispositivos infectados se comunican directamente entre sí sin un control central.



Según Propósito o Actividad Maliciosa:



Esta clasificación se basa en el tipo de actividades que realizan. Algunas Botnets se centran en enviar spam, distribuir malware, lanzar ataques de denegación de servicio (DDoS), robar información confidencial, como contraseñas o datos financieros, o incluso en minar criptomonedas utilizando los recursos de los dispositivos infectados.

Scam



También conocida como una amenaza estafadora, es una amenaza que usa técnicas de engaño para llegar a obtener información confidencial, personal o financiera con el propósito de realizar y cometer fraudes. Estas técnicas de engaño se pueden llevar a cabo de distintas formas:

1. MANIPULACIÓN PSICOLÓGICA:

Los scammers utilizan tácticas que pueden llegar a manipular y estafar a personas mediante sus emociones, deseos o miedo. Esta técnica puede salir en situaciones de emergencia y extrema urgencia o premios tentadores.

2. FALSIFICACIÓN DE IDENTIDAD:

Frecuentemente, los scammers se hacen pasar como personas confiables (ya sean bancos, empresas, gobiernos o servicios online). Para pasarse como entidades confiables usan tanto logotipos, nombres, como correos electrónicos falsos para así poder parecer legítimos.

3. COMUNICACIÓN NO SOLICITADA:

Un scam puede empezar a través de un mensaje no solicitado que se recibe sin ningún previo aviso, ya sean correos electrónicos, llamadas telefónicas, mensajes de

texto, SMS, o incluso en redes sociales como Instagram o Facebook.

4. AMENAZA E INTIMIDACIÓN:

Algunos scams pueden implicar el uso de acciones de amenaza e intimidación contra las víctimas para forzar la obtención de la información con medidas rápidas y sin ningún tipo de pensamiento lento, es decir, no dan tiempo a las víctimas de poder pensar el que hacer. Podrían ser como amenazas de arresto, demandas legales o pérdidas de cuentas.

Algunos ejemplos que puede caracterizarse por esta amenaza podrían ser como:

- Phishing.
- Llamadas falsas de soporte técnico.
- Romances online.
- Estafas en inversión.
- Herencias falsificadas.
- Fraudes para Ayuda Humanitaria.

Ransomware



La amenaza de Ransomware es un tipo de ataque informático que suele usar los ciberdelincuentes para poder cifrar archivos o el sistema de una víctima al completo. Una vez iniciado este ataque, el ciberdelincuente exige un rescate en forma de criptomonedas para así proporcionar a la víctima una llave de descifrado. Esta técnica viral entre los ciberdelincuentes ha ganado popularidad debido a su efectividad para conseguir de forma rápida beneficios económicos. Las características que tiene una amenaza Ransomware pueden ser las siguientes:

1. CIFRADO DE DATOS:

El objetivo de un Ransomware es cifrar los archivos o sistema de una víctima mediante algoritmos de cifrado muy robustos. Haciendo así que todo se vuelva inaccesible y prácticamente imposible de acceder sin una llave de descifrado.

2. DEMANDA DE RESCATE:

Después de que el ciberdelincuente haya realizado el ataque con dicho Ransomware, el mismo atacante proporciona a la víctima una oportunidad de rescate donde la víctima si sigue los pasos que el atacante le ha

dicho conforme a la realización del pago del rescate, la víctima puede volver a conseguir toda su información y datos.

3. VÍAS DE INFECCIÓN:

El Ransomware puede propagarse a través de una variedad de métodos, incluidos correos electrónicos de phishing, sitios web maliciosos, descargas ilegales de software y vulnerabilidades en sistemas operativos y software obsoletos.

4. SIGILO Y OCULTAMIENTO:

Muchas variantes de Ransomware funcionan de forma sigilosa, intentando evitar la detección durante el mayor tiempo posible para maximizar el daño y el rescate.

5. ATAQUES DIRIGIDOS Y NO DIRIGIDOS:

Algunos ataques de Ransomware se dirigen a organizaciones específicas, mientras que otros son más amplios y menos selectivos y afectan a usuarios individuales o pequeñas empresas.

Algunos tipos de Ransomwares serían como por ejemplo:

- WannaCry
- CryptoLocker
- NotPetya
- Ryuk

Bombas Lógicas



Las bombas lógicas, también conocidas como bombas de tiempo, son un tipo de malware diseñado para activarse en respuesta a determinadas condiciones o eventos. Estos eventos pueden incluir fechas y horas específicas, ejecuciones de programas específicos o cambios de datos específicos. Las bombas lógicas pueden ser parte de un programa malicioso más grande o de un programa independiente. Las características que tienen las bombas lógicas pueden ser las siguientes:

1. ACTIVACIÓN PROGRAMADA:

Las bombas lógicas están programadas para estallar en momentos específicos o en respuesta a ciertas condiciones predeterminadas. Puede permanecer inactivo durante mucho tiempo hasta que se cumplan estas condiciones.

2. DAÑO POTENCIAL:

Una vez ejecutada, la bomba lógica puede realizar una variedad de acciones maliciosas, incluida la eliminación de archivos, la corrupción de datos, la ralentización del sistema y la destrucción total de la funcionalidad del sistema informático.

3. OCULTAMIENTO:

Los creadores de las bombas lógicas a menudo intentan ocultar su presencia en los sistemas, lo que dificulta su detección antes de que exploten. Esto puede incluir formas de evitar la detección por parte del software antivirus y otras medidas de seguridad.

4. UBICUIDAD EN MALWARE:

Las bombas lógicas también se encuentran a veces en otros tipos de malware, como caballos de Troya o gusanos, como una forma de maximizar el impacto de un ataque.

5. PROGRAMACIÓN VERSÁTIL:

Algunas bombas lógicas contienen una programación extensa, lo que permite a un atacante cambiar las condiciones de activación o las acciones tomadas después de la activación sin cambiar el código fuente.

Algunos ejemplos de bombas lógicas podrían ser como por ejemplo:

- Bomba lógica basada en fecha.
- Activación por comando remoto.
- Bomba lógica dentro de un documento.
- Modificación de datos.

Biografía:

Man-in-the-middle:

[¿Qué es el ataque 'Man in the Middle', por qué es tan peligroso y cómo puedes protegerte? | Computer Hoy](#)

[Suplantación de ARP - Wikipedia, la enciclopedia libre](#)
[DNS spoofing | Minery Report S.L.](#)

[Ataques SSL Stripping: Qué son, peligros y cómo evitar que nos ataquen \(redeszone.net\)](#)

[¿Sabes lo que es el 'WiFi eavesdropping'? Esto tienes que hacer si te conectas a redes públicas \(20minutos.es\)](#)

[¿Qué es el secuestro de sesión \(session hijacking\) y cómo prevenirlo?](#)

[Blog | GlobalSign](#)

[Email Hijacking - GeeksforGeeks](#)

[Qué es el clickjacking y cómo evitarlo \(kaspersky.es\)](#)
[Botnet: características, tipos, usos... - MSMK University](#)

Botnet:

[Botnet - Wikipedia, la enciclopedia libre](#)

[What is Botnet - Types, Detection Techniques, and Prevention Methods \(efani.com\)](#)

Scam:

[https://uniblog.unicajabanco.es/-que-es-el-scam-](#)

<https://es.godaddy.com/blog/que-es-un-scam-y-como-protegers-e-ante-este-ataque/>

<https://conceptodefinicion.de/scam/>

<https://www.pandasecurity.com/es/security-info/scam/>

Ransomware:

<https://www.ibm.com/es-es/topics/ransomware>

<https://www.eset.com/es/caracteristicas/ransomware/>

<https://www.kaspersky.es/resource-center/threats/ransomware>

<https://www.nomoreransom.org/es/prevention-advice.html>

Bombas Lógicas:

<https://masterenciberseguridadonline.es/internet/que-hace-una-bomba-logica/>

<https://www.avast.com/es-es/c-what-is-a-logic-bomb>

<https://techlib.net/techedu/bomba-logica/>

https://www.wikiwand.com/es/Bomba_l%C3%B3gica